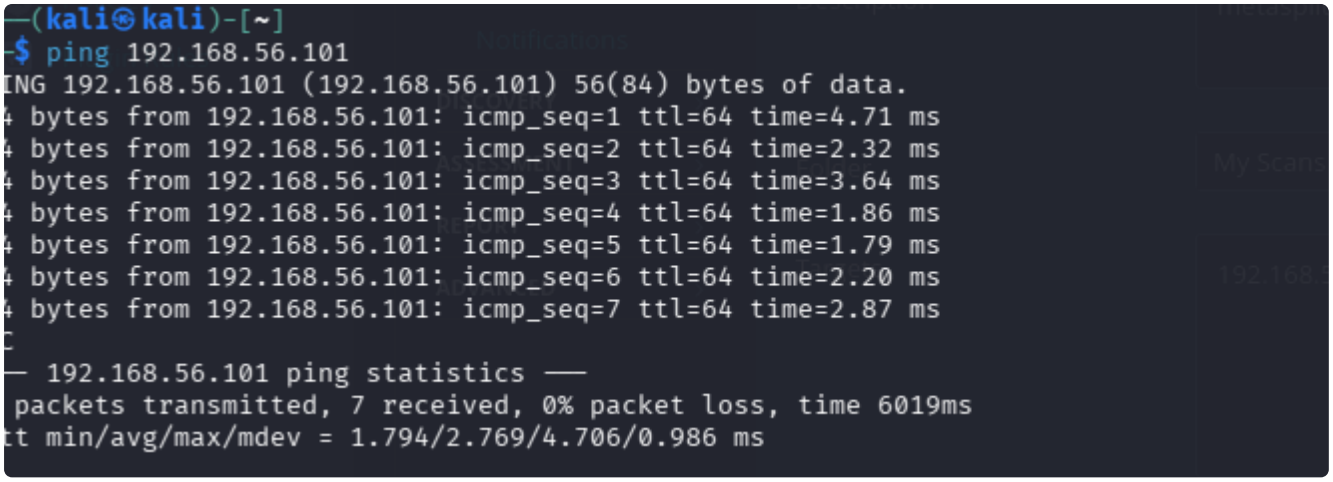
Lab Report: Credentialed Scan & Local System Audit

1.1 Lab Environment Setup

The objective of this lab was to perform a credentialed vulnerability scan to discover internal system vulnerabilities that a network-only (unauthenticated) scan would miss.

- **Selected Target:** Metasploitable 2
- **Target IP Address:** 192.168.56.101
- **Scanner:** Nessus Essentials (Local Scanner), run from Kali Linux
- **Pre-Lab Checklist:** Completed. The target VM was powered on, and a ping test confirmed network reachability (7 packets transmitted, 7 received, 0% packet loss).

Fig 1: Ping test confirming the target VM is reachable from Kali



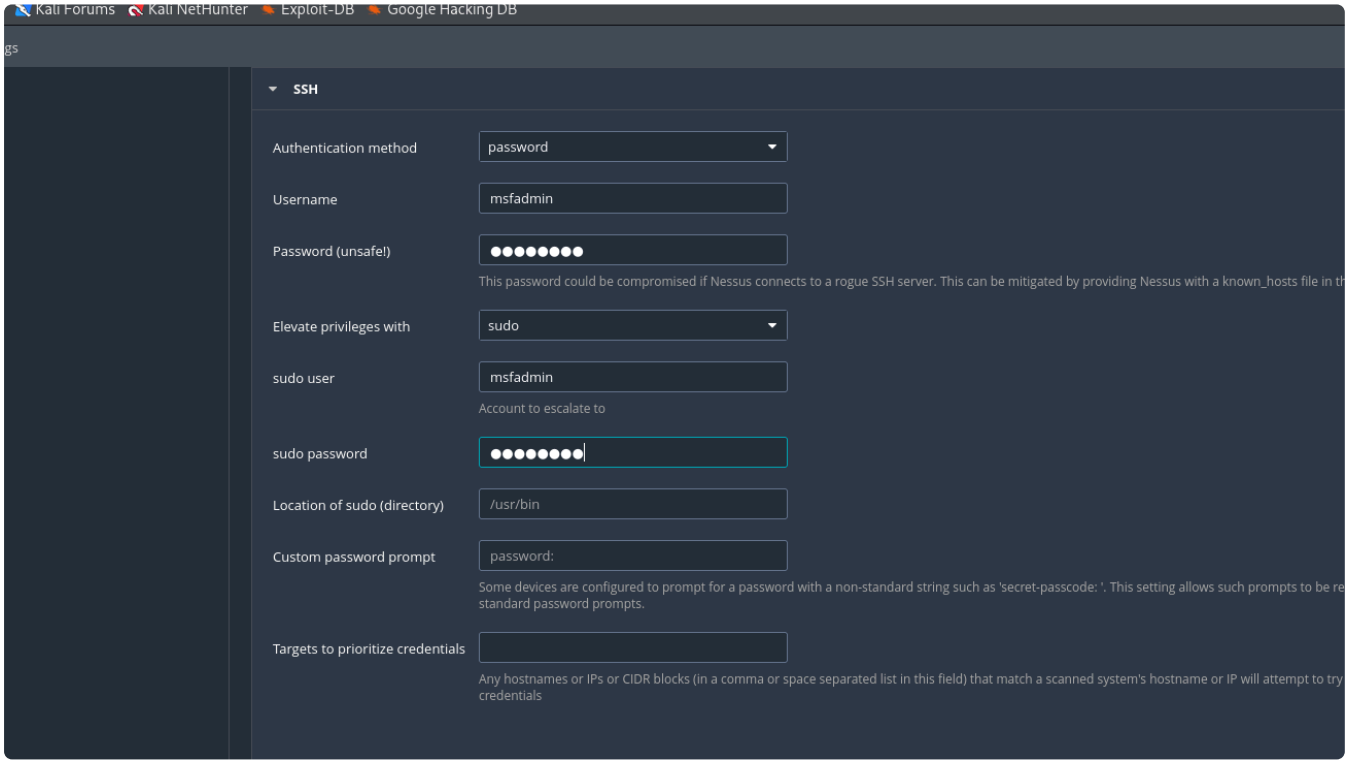
1.2 Configuring Credentials in Nessus

To allow Nessus to perform local checks, SSH credentials were configured in the scan's own Credentials tab. Because the msfadmin account needs elevated privileges to read certain local files, privilege escalation via sudo was configured.

Field	Entry
Credential Type	SSH
Username	msfadmin
Authentication Method	Password

Field	Entry
Elevate privileges with	sudo (sudo user: msfadmin, sudo binary location: /usr/bin)
Target IP	192.168.56.101
Credential Verification	Yes (Auth: Pass shown in scan results)

Fig 2: Nessus SSH credential configuration (password hidden)



1.3 Scan Configuration & Execution

The scan was executed using the **Basic Network Scan** policy against a single host. The credentials were applied successfully, as shown by the Auth: Pass indicator on the results page.

Metric	Value
Scan Start Time	5:25 PM
Scan End Time	5:52 PM
Total Duration	27 minutes
Scanner	Local Scanner
Severity Base	CVSS v3.0

Metric	Value
Hosts Scanned	1

Fig 3: Scan settings page showing the target 192.168.56.101

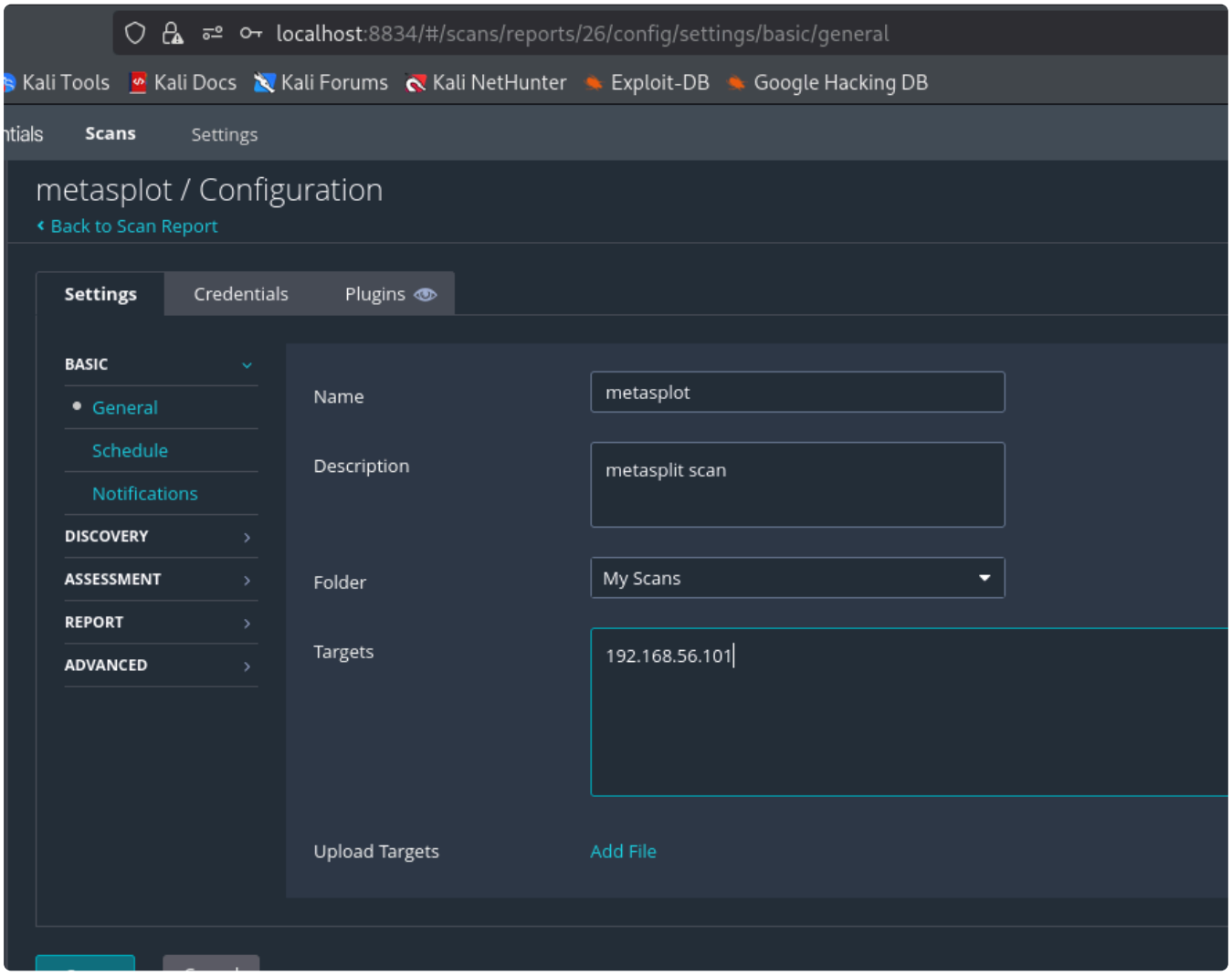


Fig 4a: Scan in progress (started 5:25 PM, Auth still N/A at 2%)

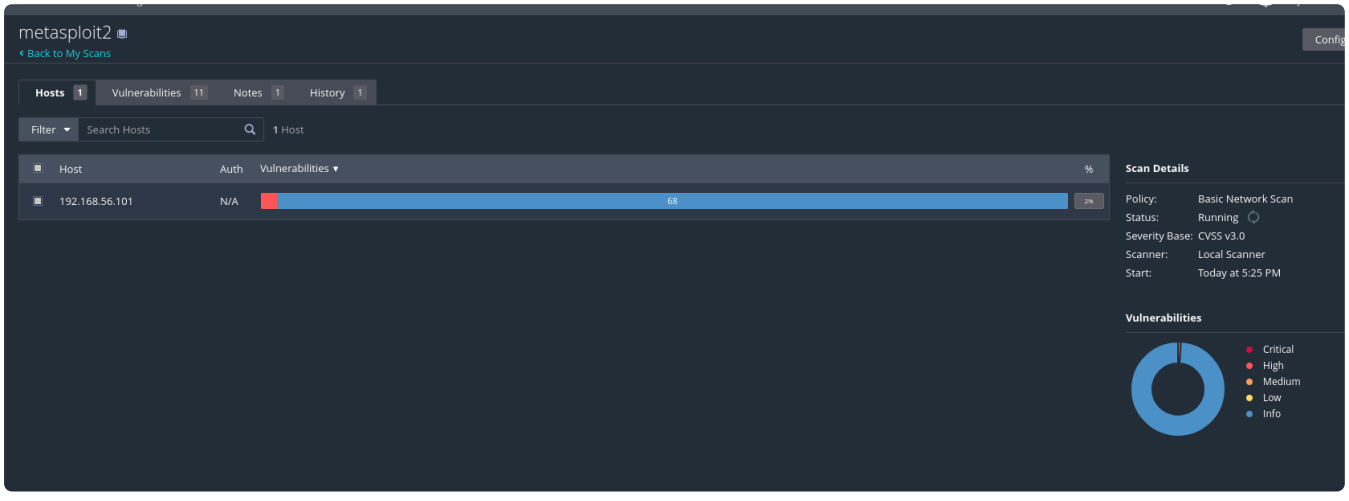
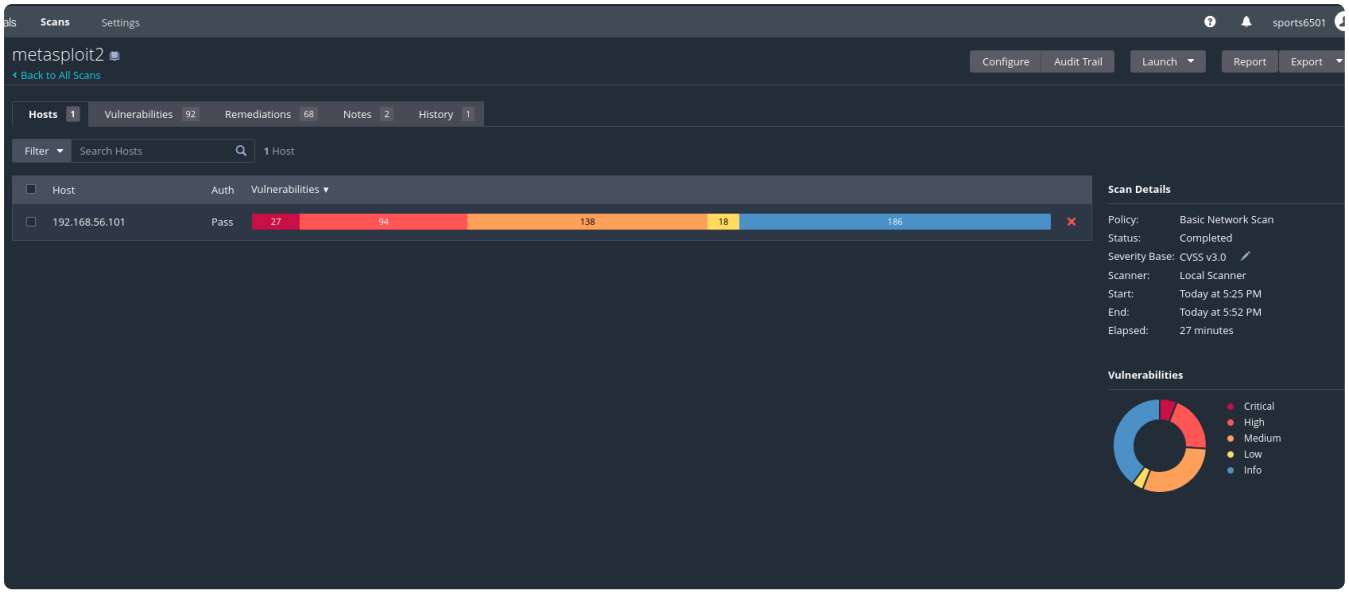


Fig 4b: Scan completed (27 minutes elapsed, Auth: Pass)



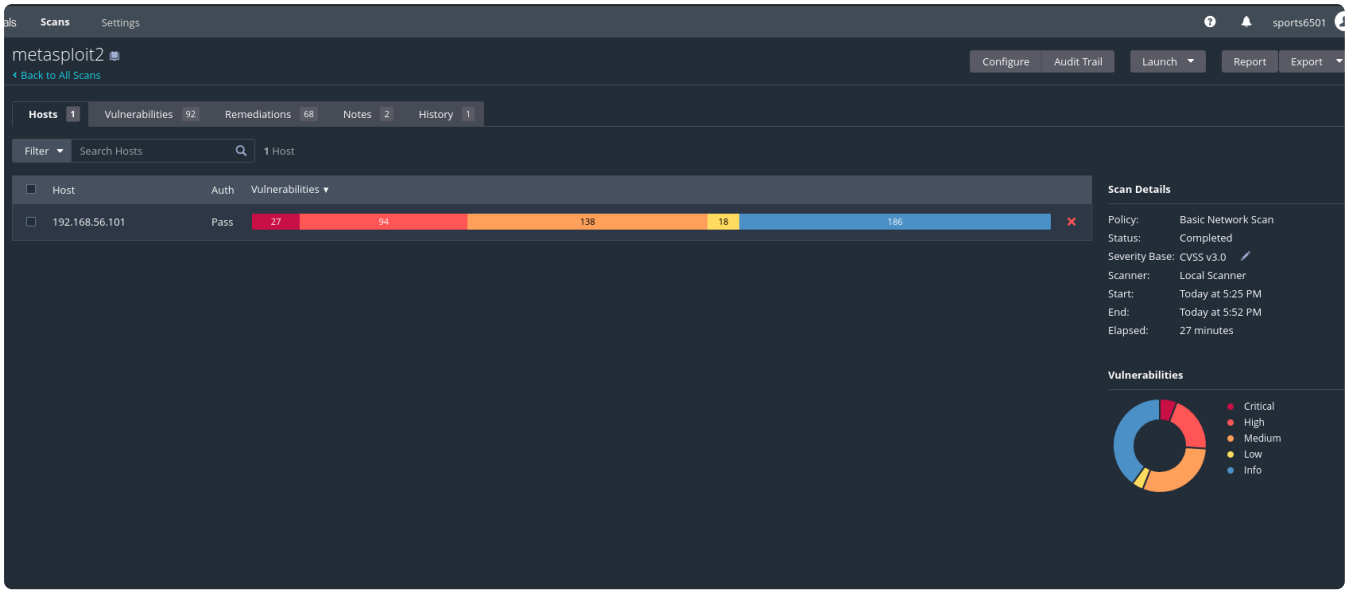
1.4 Results Analysis: Credentialed vs Unauthenticated

The credentialed scan reported 92 unique vulnerabilities (plugins) and 68 remediations. Because Metasploitable 2 is intentionally vulnerable, an unauthenticated scan would still find many network-based flaws. However, the credentialed scan authenticated successfully (Auth: Pass) and exposed local misconfigurations and missing patches that are invisible from the network.

Note: Unauthenticated figures are estimates based on a typical unauthenticated scan of Metasploitable 2, not measured values.

Severity	Credentialed Scan	Unauthenticated Scan (Est.)
Critical	27	~10
High	94	~20
Medium	138	~30
Low	18	~15
Info	186	~100
Total	**463**	**~175**

Fig 5: Results summary for the credentialed scan (severity bar and donut chart)



Three vulnerability types that appear only (or mostly) in a credentialed scan:

1. **Missing OS patches (Ubuntu local security checks):** Nessus needs local access to read the installed package inventory (via dpkg) to find outdated libraries that are not exposed to the network.
2. **Insecure file permissions (e.g. world-writable files):** These exist on the local disk and have no network footprint.
3. **Local configuration weaknesses (e.g. sudo and account settings):** Nessus must log in to read files such as /etc/sudoers and check them. *Before submitting, confirm the exact plugin names for items 2 and 3 in your own Vulnerabilities tab.*

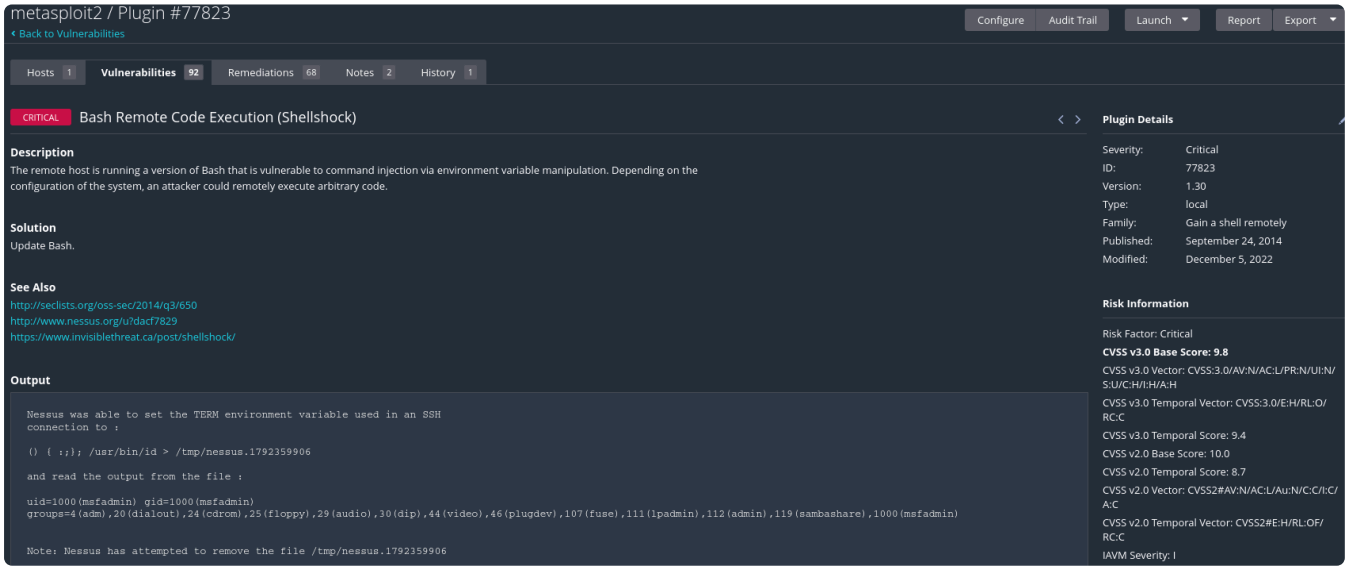
1.5 Deep Dive: One Local Vulnerability

For this deep dive, the Shellshock vulnerability was analysed. Nessus confirmed it through the SSH session.

Field	Detail
Plugin Name	Bash Remote Code Execution (Shellshock)
Plugin ID	77823 (type: local)
CVE ID	CVE-2014-6271
Severity / CVSS	Critical, CVSS v3.0 base score 9.8 (v3.0 temporal 9.4; v2.0 base 10.0)
Plugin Family	Gain a shell remotely

Field	Detail
Plugin Output	Nessus set the TERM environment variable used in an SSH connection to a crafted function definition that ran /usr/bin/id and wrote to /tmp/nessus.1792359906, then read the file back: uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm), 20(dialout), 24(cdrom), 25(floppy), 29(audio), 30(dip), 44(video), 46(plugdev), 107(fuse), 111(lpadmin), 112(admin), 119(sambashare), 1000(msfadmin). Nessus then attempted to remove the file.
Root Cause	The target runs a vulnerable GNU Bash that does not properly parse function definitions in environment variables, so trailing commands get executed.
Potential Impact	An attacker can inject arbitrary commands through environment variables, leading to remote code execution and possible full system compromise.
Remediation	Update Bash to a patched version. On Debian/Ubuntu: sudo apt-get update && sudo apt-get install --only-upgrade bash

Fig 6: Nessus finding detail page for Shellshock (Plugin #77823)



1.6 Reflection Questions

Q1: Explain in your own words why organisations should always prioritise credentialed scanning over unauthenticated scanning for internal systems.

Credentialed scanning gives an inside-out view of a system's security posture. An unauthenticated scan only evaluates what is exposed to the network, so it misses vulnerabilities hidden in local package versions, configuration files and permission settings. With credentials, the scanner can query the OS package manager directly to identify missing patches and check local misconfigurations instead of guessing from network banners, which gives more accurate data and fewer false positives.

Q2: What security risks exist in storing scan credentials inside a vulnerability scanner? How would you mitigate these risks?

The main risk is that the scanner becomes a high-value target: if an attacker compromises the Nessus server, they gain privileged credentials for every host it scans. Nessus itself warns that a password could be exposed if the scanner connects to a rogue SSH server. Mitigations include dedicated least-privilege scan accounts (not domain admins), frequent password rotation, SSH key authentication instead of passwords, providing a known_hosts file, strict control of the Nessus web interface (MFA, network segmentation) and auditing of scanner access.

Q3: How would you handle a situation where a credentialed scan is not possible on certain hosts (e.g. legacy systems, locked accounts)?

A layered, compensating approach is needed. First, run unauthenticated scans to identify network-exposed risks. Second, use agent-based scanning if the OS supports it, or review software inventories through a CMDB. For legacy systems that cannot be scanned, isolate them on a segmented VLAN with minimal network access, document the gap as a formally accepted risk exception, and carry out manual local audits during maintenance windows.